

# Vulnerability Assessment Report

*Fictional scenario. Qualitative risk assessment following NIST SP 800-30 Rev. 1, completed as part of the Google Cybersecurity Professional Certificate.*

Report date: 15 March 2026

## System Description

The server hardware consists of a modern multi-core CPU and 128GB of memory, running the latest version of the Linux operating system and hosting a MySQL 8.0 database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the corporate network. Security measures include SSL/TLS encrypted connections. The database stores customer, campaign, and analytics data queried daily by a fully remote workforce to identify and pursue potential customers. Since the company's launch three years ago, the database has been reachable from any public IP address, with no network-layer access restriction limiting connections to approved company sources.

## Technical Findings

A network scan of the server's public IP address was performed to confirm exposure. Simulated scan output, representative of the type of finding this assessment is based on:

```
$ nmap -sV -Pn 203.0.113.50

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 8.0.34-0ubuntu0.22.04.1
| mysql-info:
| Protocol: 10
| Version: 8.0.34-0ubuntu0.22.04.1
| Capabilities flags: 65535
| Auth Plugin Name: mysql_native_password
|_ Salt: <redacted>

Bind address: 0.0.0.0 (all interfaces, no firewall restriction)
TLS: SSLv3/TLS 1.0 accepted (deprecated protocol versions not disabled)
```

This confirms three concrete issues: (1) the database port is reachable from any public IP address, with no firewall or security group restricting inbound connections; (2) the server's MySQL version and authentication plugin are visible to any unauthenticated scanner, providing reconnaissance value to an attacker; and (3) the server still accepts outdated SSL/TLS protocol versions, weakening the encryption intended to protect data in transit.

## Scope

This vulnerability assessment focuses on the current network-layer and access-layer controls of the database server, specifically the confidentiality, integrity, and availability of the data it stores. The physical security of the server and related IT infrastructure is outside the scope of this assessment. The assessment covers a three-month period, from June 2026 to August 2026, and is guided by NIST SP 800-30 Rev. 1.

## Purpose

The database server is a core business asset that stores customer, campaign, and analytics data used by remote employees across the organization to identify and pursue potential customers. Because the server has remained publicly reachable since the company's launch, any individual with network access could potentially query, alter, or exfiltrate this data without authorization. Securing the server is essential to protecting customer trust and complying with data protection obligations, and this assessment is intended to communicate that risk clearly to decision-makers and support a timely remediation decision.

## Risk Assessment

| Threat Source         | Threat Event                                                | Likelihood | Severity | Risk |
|-----------------------|-------------------------------------------------------------|------------|----------|------|
| Hacker (external)     | Obtain sensitive customer information via exfiltration      | 3          | 3        | 9    |
| Competitor            | Perform reconnaissance and surveillance of the organization | 2          | 2        | 4    |
| Employee (accidental) | Alter or delete critical customer/campaign data             | 2          | 3        | 6    |

## Approach

This is a qualitative assessment, with likelihood and severity scored on a 1-3 scale per NIST SP 800-30 Rev. 1 definitions, based on the technical findings above and the resulting business exposure.

**Hacker, exfiltration (Likelihood 3, Severity 3, Risk 9):** Likelihood is scored High because the scan confirms the database port is open to the entire internet with no access restriction, and the exposed MySQL banner gives an attacker immediate reconnaissance value with no additional effort. Severity is scored High because the data at risk, customer and campaign records, is sensitive, and a breach would carry both direct business impact and regulatory exposure.

**Employee, accidental alteration (Likelihood 2, Severity 3, Risk 6):** Likelihood is scored Moderate because there is currently no evidence of role-based restrictions limiting which employees can write to the database, meaning any of the many remote employees querying the system daily could make an unintended change, though this requires an actual mistake rather than intent. Severity is scored High because altered or deleted campaign/customer data would directly disrupt day-to-day marketing operations.

**Competitor, reconnaissance (Likelihood 2, Severity 2, Risk 4):** Likelihood is scored Moderate because the exposed service banner and open port make basic reconnaissance easy to perform, but a competitor is less likely than a hacker to escalate reconnaissance into a damaging attack. Severity is scored Moderate because reconnaissance alone does not compromise data, but it lowers the cost of a future, more damaging attack.

## Remediation Plan

The following plan addresses each identified risk with a specific control, an assigned owner, and a target timeline, prioritized by risk score.

| <b>Risk Addressed</b>                           | <b>Recommended Control</b>                                                                                                        | <b>Priority</b> | <b>Owner</b>                | <b>Timeline</b> |
|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|-----------------|-----------------------------|-----------------|
| Exfiltration by external hacker (Risk 9)        | Restrict database access to an IP allow-list of approved corporate/VPN ranges; disable public bind address                        | Immediate       | Network/Infrastructure team | Within 1 week   |
| Exfiltration by external hacker (Risk 9)        | Enforce MFA and role-based access for all database accounts                                                                       | Immediate       | IT Security                 | Within 2 weeks  |
| Accidental data alteration by employee (Risk 6) | Apply least-privilege roles (read-only for query/analytics use, write access limited to named admins); enable query audit logging | High            | Database Administrator      | Within 30 days  |
| Reconnaissance by competitor (Risk 4)           | Upgrade encrypted connections from SSL to TLS 1.2+; disable verbose database banner/version disclosure                            | Medium          | IT Security                 | Within 60 days  |

Restricting network access (IP allow-listing) is listed first because it eliminates the majority of the exfiltration risk at the lowest implementation cost, without requiring any change to how employees already authenticate. MFA and role-based access follow immediately after, since they directly reduce the impact of a compromised credential or an overly broad employee permission. The TLS and banner-hardening items are scheduled last, as they reduce reconnaissance value and defense-in-depth rather than close the primary exposure, and can be completed without disrupting active business operations.